LOF CRM Test Documentation

Oct 12, 2026 · @Mushtaq

All 156 automated tests and 13 browser tests pass on build 2026-10-12 (version 2: counsellor targets, payment terms and instalments, refund rules, LMS integration; database browser, export and backup added 2026-10-23); no open defects of high or critical severity.

Summary of results

Level	Cases	Passed	Failed	Tool
Unit	23	23	0	Vitest
API and business rules (incl. the four new features)	47	47	0	Vitest on the real Worker
Integrations (webhooks, adapters, Testing console)	32	32	0	Vitest with stubbed provider APIs
Security regression	41	41	0	Vitest
Database browser, export, backup and restore	13	13	0	Vitest on the real Worker
Browser end-to-end	13	13	0	Playwright + Chromium against wrangler dev
Total	169	169	0	

Also run: TypeScript type check (clean) and a production build dry run. Four independent review rounds were run (three on the base system, one on the new features); every high and critical finding is fixed and covered by a case in this catalogue.

Test strategy

Level	What it proves	How
Unit	Pure logic is correct: crypto, fee maths, template parameters, provider message parsing, live/mock switching	Direct function calls

Level	What it proves	How
API and business rules	Every endpoint and every sync guard enforces role, branch, approval, fee and money rules	The real Hono app and sync code, called with real HTTP requests
Integrations	Each provider is called with the exact request format; webhooks are verified, idempotent and recorded once	Provider HTTP APIs replaced by stubs that fail loudly on any unexpected call
Security regression	Each finding from the three review rounds stays fixed	One or more cases per finding, named with the finding code (C1, H1–H6, M1–M7, L1–L4, N1–N14)
End-to-end	The real screens work with the real server: sign-in, lead, payment, enrolment, approval, settings, branch isolation	Playwright drives Chromium against wrangler dev with a local D1 database
Scenario	Whole business journeys across integrations	Testing console scenarios, run both in automated tests and by an administrator in the app

Environment: Node 22, an in-memory SQLite database built from the same four migrations as production (0001 schema, 0002 seed, 0003 reporting views, 0004 security), and every integration in mock mode unless a test stubs the provider for live mode. No network or Cloudflare account is needed.

Test data: the prototype's demo dataset (5 branches, 6 roles, sample leads, students, enrolments and payments), regenerated from the approved prototype for every run. Every test starts from a fresh database. Testing console records use TST- numbers and never touch business data or numbering.

How to run the tests

```
npm install
npm test                 # 120 automated cases, about 20 seconds
npm run typecheck
npm run db:migrate:local # once, for the browser tests
npm run test:e2e         # 10 browser cases against wrangler dev, about 40
seconds
```

Set CHROME_PATH to use an existing Chromium. The browser suite resets demo passwords and sign-in rate limits on the local database before it runs. The GitHub workflow (.github/workflows/deploy.yml) runs the type check and the automated suite before every deployment and stops the deployment if any case fails.

Test case catalogue

Every automated case, as it runs in the suite on 12 October 2026. Each description states the expected behaviour; all 120 passed.

Unit (23)

ID	Group	Test case – expected behaviour	Result
UNI-01	crypto	HMAC-SHA256 matches the RFC 4231 test vector	Pass
UNI-02	crypto	JWT round-trips and rejects tampering and expiry	Pass
UNI-03	crypto	PBKDF2 password hashes verify only the right password	Pass
UNI-04	fees	Adds registration for new students and VAT on the net	Pass
UNI-05	fees	Applies percentage and capped flat discounts to the programme fee only	Pass
UNI-06	fees	Picks only fee records effective on the date	Pass
UNI-07	templates	Fills placeholders and extracts WhatsApp template parameters in order	Pass
UNI-08	payment terms	Splits the total, puts rounding on the last instalment and spaces due dates	Pass
UNI-09	payment terms	Applies payments to the earliest instalment and marks overdue only after the grace days	Pass
UNI-10	payment terms	Validates term definitions	Pass
UNI-11	refund rules	Uses the first rule within both limits, adds tax on the share, deducts the admin fee	Pass

ID	Group	Test case – expected behaviour	Result
UNI-12	refund rules	Gives 0 when no rule matches and never more than was paid	Pass
UNI-13	refund rules	Rejects malformed rule sets and targets	Pass
UNI-14	LMS payload	Matches the LOF booking platform sheet (v3) and carries no payment data	Pass
UNI-15	LMS payload	Lists missing required fields instead of sending an incomplete call	Pass
UNI-16	Exotel	Normalises status callbacks	Pass
UNI-17	Meta Lead Ads	Parses leadgen webhooks and maps form fields to a lead	Pass
UNI-18	WhatsApp	Parses statuses and inbound messages	Pass
UNI-19	WhatsApp	Verifies X-Hub-Signature-256	Pass
UNI-20	integration plumbing	Redacts secrets and tokens from logs	Pass
UNI-21	integration plumbing	Goes live only when enabled and fully configured	Pass
UNI-22	integration plumbing	Routes AED to Telr and INR to Razorpay	Pass
UNI-23	integration plumbing	Indexes leads by normalised phone and child records by parent branch	Pass

Smoke and admin script (2)

ID	Group	Test case – expected behaviour	Result
SMK-01	smoke	Health, login and bootstrap	Pass
ADM-01	create-admin script	Creates a System Administrator who can sign in and open the Testing console; stores only a hash; re-running updates instead of duplicating	Pass

Authentication and guarded sync (23)

ID	Group	Test case – expected behaviour	Result
AUT-01	authentication	Rejects wrong passwords and locks the account after 5 attempts	Pass
AUT-02	authentication	Requires a token on API routes	Pass
AUT-03	authentication	Forces a strong password change before anything else works	Pass
AUT-04	authentication	Allows role preview only when impersonation is enabled	Pass
AUT-05	branch-scoped bootstrap	A Karama counsellor sees only Karama leads	Pass
AUT-06	branch-scoped bootstrap	The India Admissions Head sees Bengaluru and Hyderabad only	Pass
AUT-07	branch-scoped bootstrap	Management sees every branch and the audit log	Pass
AUT-08	branch-scoped bootstrap	Never sends password hashes	Pass
AUT-09	guarded sync	Lets a counsellor update a lead in scope and records it	Pass
AUT-10	guarded sync	Blocks edits outside the branch scope	Pass
AUT-11	guarded sync	Blocks changing branch without an approved transfer and reassignment without rights	Pass
AUT-12	guarded sync	Applies a branch transfer when the Admissions Head approves it	Pass
AUT-13	guarded sync	Enforces approver rules: role, requester and decided state	Pass
AUT-14	guarded sync	Rejects an exceptional discount on an opportunity unless it was approved	Pass
AUT-15	guarded sync	Re-checks enrolment fees on the server	Pass

ID	Group	Test case – expected behaviour	Result
AUT-16	guarded sync	Records payments with server receipt numbers and recomputes the balance	Pass
AUT-17	guarded sync	Blocks messages without consent and queues the rest for delivery	Pass
AUT-18	guarded sync	Keeps the audit log append-only and stamps the real user	Pass
AUT-19	guarded sync	Only configuration roles can change settings, and secrets are stripped	Pass
AUT-20	guarded sync	Creates a login with a temporary password when staff are added	Pass
AUT-21	guarded sync	Rolls back the whole batch when one change is rejected	Pass
AUT-22	sequences	Claims gapless numbers and resolves concurrent claims	Pass
AUT-23	enrolment with first payment	Lets a Centre Administrator take the first payment inside a new enrolment, but not standalone payments	Pass

REST resources (6)

ID	Group	Test case – expected behaviour	Result
API-01	leads	Creates a lead with routing and detects duplicates	Pass
API-02	leads	Validates input and branch scope	Pass
API-03	leads	Lists leads with filters inside scope	Pass
API-04	students	Serves a student 360 and a printable receipt	Pass
API-05	payments	Lets Reception send a payment link to the parent	Pass
API-06	notifications	Returns notifications filtered for the role	Pass

Counsellor targets, payment terms, refund rules and LMS (16)

ID	Group	Test case – expected behaviour	Result
FEA-01	payment terms	Builds the instalment schedule on the server from the chosen term; Track and Credit codes come from settings	Pass
FEA-02	payment terms	Refuses an inactive or unknown payment term	Pass
FEA-03	payment terms	Keeps the schedule and term fixed after enrolment	Pass
FEA-04	payment terms	Notifies Reception once per overdue instalment	Pass
FEA-05	refund rules	Suggests a refund from the rules and marks larger requests as exceptions only the approver role can process	Pass
FEA-06	refund rules	Needs the sessions attended	Pass
FEA-07	LMS calls	Creates one cancel call per withdrawal and refuses cancel calls without one; a withdrawal cannot be reversed	Pass
FEA-08	LMS calls	Previews the enrol call for an enrolment, within branch scope	Pass
FEA-09	settings validation	Accepts valid settings and strips LMS credentials	Pass
FEA-10	settings validation	Rejects bad payment terms, refund rules, targets and LMS codes	Pass
FEA-11	counsellor targets	Counsellors see only their own targets; managers see achievement for everyone in scope	Pass
FEA-12	counsellor targets	Fills defaults for databases created before these settings existed	Pass
FEA-13	review fixes	A refund split into two requests still needs approval once the suggestion is used up	Pass
FEA-14	review fixes	The person who requested an exception cannot approve it; the approver can reject it	Pass
FEA-15	review fixes	Never re-opens LMS access after a withdrawal, and a successful call cannot be re-run	Pass
FEA-16	review fixes	Clamps valid_until at month end	Pass

Webhooks (12)

ID	Group	Test case – expected behaviour	Result
WHK-01	website lead capture	Creates, routes and greets a lead from a signed submission	Pass
WHK-02	website lead capture	Rejects unsigned or tampered submissions	Pass
WHK-03	website lead capture	Accepts browser posts from an allowed origin and ignores bots (honeypot)	Pass
WHK-04	website lead capture	Refuses a programme the branch does not offer	Pass
WHK-05	Meta Lead Ads	Verifies the subscription and imports a lead once	Pass
WHK-06	WhatsApp	Updates delivery status and threads inbound replies onto the lead	Pass
WHK-07	WhatsApp	Rejects unsigned events	Pass
WHK-08	Exotel	Pops incoming calls to the assigned counsellor and logs completed calls	Pass
WHK-09	Exotel	Rejects requests without the shared token	Pass
WHK-10	payment gateways	Razorpay: signed payment_link.paid records the payment once	Pass
WHK-11	payment gateways	Telr: transaction advice is confirmed with Telr before recording	Pass
WHK-12	payment gateways	Refuses links above the outstanding balance	Pass

Live adapters against stubbed providers (9)

ID	Group	Test case – expected behaviour	Result
ADP-01	LMS	Sends the enrol call with the exact fields from the sheet, the bearer token and no payment data	Pass
ADP-02	LMS	Treats an LMS refusal as a failure and escalates after the retry limit	Pass

ID	Group	Test case – expected behaviour	Result
ADP-03	LMS	Does not send an incomplete call: missing codes wait for a person	Pass
ADP-04	LMS	Sends the cancel call with the reference only when an enrolment is withdrawn	Pass
ADP-05	WhatsApp Cloud API	Sends approved templates with body parameters when a template is mapped	Pass
ADP-06	WhatsApp Cloud API	Records provider errors on the message and the lead timeline	Pass
ADP-07	Exotel click-to-call	Rings the counsellor first, then the parent, with a status callback	Pass
ADP-08	ERPNext	Creates the customer and a draft Payment Entry for a CRM payment	Pass
ADP-09	ERPNext	Keeps the error on the payment for the scheduler to retry	Pass

Testing console (11)

ID	Group	Test case – expected behaviour	Result
TCN-01	access	Refused for roles other than System Administrator	Pass
TCN-02	readiness	Reports readiness of every integration	Pass
TCN-03	connection tests	Runs a connection test per integration	Pass
TCN-04	scenarios	UAE lead to enrolment, payment, LMS enrol call, withdrawal and LMS cancel call passes end to end	Pass
TCN-05	scenarios	India lead to enrolment passes end to end	Pass
TCN-06	scenarios	Meta lead import passes end to end	Pass
TCN-07	scenarios	LMS outage and retry passes end to end	Pass
TCN-08	simulations	Simulates each webhook through the real handler and only touches test data	Pass
TCN-09	test data	Keeps business sequences gapless and cleans up	Pass
TCN-10	logs	Lists logs with secrets redacted	Pass

ID	Group	Test case – expected behaviour	Result
TCN-11	scheduler	SLA escalation and overdue follow-up notifications, without duplicates on a second run	Pass

Security – review round 1, sessions, two-step (29)

ID	Group	Test case – expected behaviour	Result
SEC-01	sync input validation	Rejects unknown operations instead of skipping the guards	Pass
SEC-02	sync input validation	Requires the document id to match and to be a safe id	Pass
SEC-03	sync input validation	Caps record size	Pass
SEC-04	sync input validation	Payments and audit entries cannot be overwritten, even by an administrator	Pass
SEC-05	branch scope	Blocks moving another branch's opportunity, student or task into your branch	Pass
SEC-06	approvals	A rejected transfer cannot move the lead, and an approved one only to the approved branch	Pass
SEC-07	approvals	Rebuilds new requests on the server (approver, payload, history)	Pass
SEC-08	approvals	Refuses a discount request on another branch's opportunity	Pass
SEC-09	fee integrity	Rejects invented discount kinds and reused approvals	Pass
SEC-10	fee integrity	Rejects enrolments for students outside your branches	Pass
SEC-11	server-owned fields	Ignores client test flags and backdating on payments; invented payment ids refused	Pass
SEC-12	server-owned fields	LMS call records can only be created with their enrolment and are built on the server	Pass
SEC-13	server-owned fields	Appended student messages are recorded but never sent with client text	Pass
SEC-14	server-owned fields	Notifications are sanitised and attributed	Pass

ID	Group	Test case – expected behaviour	Result
SEC-15	server-owned fields	Refund requests start as Requested; calls are attributed to the caller	Pass
SEC-16	concurrent edits	Two people changing different fields of the same lead both keep their change	Pass
SEC-17	concurrent edits	Appends to history lists from both sides	Pass
SEC-18	database integrity	A trigger blocks overpayment and payment/audit changes even if application code is bypassed	Pass
SEC-19	payment links	A mock link is never marked paid from the return URL in production	Pass
SEC-20	payment links	Lists only links in your branches	Pass
SEC-21	API hygiene	Clamps paging and redacts webhook tokens in logs	Pass
SEC-22	API hygiene	Sets security headers on API responses	Pass
SEC-23	API hygiene	Refuses to run with a weak server secret	Pass
SEC-24	browser sessions	Works with the cookie, and refuses cookie writes without the CSRF header	Pass
SEC-25	browser sessions	Logout and password change end sessions	Pass
SEC-26	browser sessions	Ends idle sessions	Pass
SEC-27	browser sessions	Rate-limits sign-in attempts	Pass
SEC-28	two-step verification	Enrol, then sign-in needs a valid, unused code	Pass
SEC-29	two-step verification	Roles that require it must enrol before using the CRM	Pass

Security – review rounds 2 and 3 (12)

ID	Group	Test case – expected behaviour	Result
SR2-01	record numbers	Refuses new records whose number was never issued	Pass

ID	Group	Test case – expected behaviour	Result
SR2-02	record numbers	Accepts a number handed out by /seq/block	Pass
SR2-03	append-only history	Refuses rewriting an existing history entry and stamps appended ones	Pass
SR2-04	refunds	Caps the total of refund requests at the amount paid	Pass
SR2-05	rule ordering	An edit to paid in the same save cannot lift the refund cap	Pass
SR2-06	permissions	A counsellor sees the student but not payments	Pass
SR2-07	REST lead creation	Ignores server-owned fields and checks the chosen counsellor	Pass
SR2-08	sign-in hardening	Accepts sign-in only as JSON and only from this site	Pass
SR2-09	sign-in hardening	Rate-limits turning two-step verification off	Pass
SR2-10	sign-in hardening	Rate-limits sequence blocks	Pass
SR2-11	integration safety	Test records never reach live providers in production	Pass
SR2-12	integration safety	Removes any configured secret from integration logs	Pass

Database browser, export and backup (13)

test/api/database.test.ts, plus browser test 13.

ID	Case	Expected	Result
DB-01	Counsellor, Centre Administrator and Reception open /admin/db/tables; no session	403 for each role; 401 without a session	Pass
DB-02	List datasets	All 19 datasets with row counts; instalments has more rows than enrolments; targets populated	Pass

ID	Case	Expected	Result
DB-03	Page, search, branch filter, test records	limit respected and total returned; BLR filter returns only BLR; search finds one student; a test lead is hidden unless test=1	Pass
DB-04	Secrets never exposed	Staff has no password_hash column and no hash text; sessions have no id_hash; staff_auth and a UNION injection in name return 404	Pass
DB-05	Open a record	Full enrolment JSON with type meta; integration-log row opens with its integration	Pass
DB-06	CSV export	text/csv with dated file name; fixed header; a =HYPERLINK cell is prefixed with ' ; one audit entry	Pass
DB-07	Backup and restore round trip	lof-crm-backup/1 with every record, setting and sequence and no hashes; restore-backup.mjs SQL rebuilds the same lead, enrolment, payment and refund counts in a fresh database	Pass
DB-08	Backup rate limit	Sixth backup within the hour gets 429	Pass
DB-09	Odd input: name=constructor/__proto__/toString, offset=1e400, non-numeric log id	404 for the names, 400 for the numbers – never a server error	Pass
DB-10	Search for % and _	Matched literally (no wildcard), so no leads match	Pass
DB-11	CSV with a negative amount	-50 stays a number (no ' prefix); x-lof-truncated is 0	Pass

ID	Case	Expected	Result
DB-12	Backup when settings hold an LMS token	Token not present in the backup file	Pass
DB-13	Restore into a database that already has business records	Stops at the guard (CHECK constraint) before writing anything	Pass
E2E-13	System Administrator: Settings → Database	Browse enrolments, search, open the record (term PT3), open staff (has_login, no hash), Export CSV downloads lof-staff-<date>.csv; a counsellor gets 403	Pass

Browser (end-to-end) test cases

ID	Role	Steps	Expected result	Result
E2E-01	Counsellor (Karama)	Sign in; New lead; fill student, parent, mobile, programme; Create lead; then mark it Lost	Lead appears with summary; the API returns exactly one matching lead in KRM with source Manual; status becomes Lost; session cookie not readable by page scripts	Pass
E2E-02	Counsellor	Sign in; open Configuration directly	Settings not in the menu; page shows Access restricted	Pass
E2E-03	System Administrator	Testing console → run UAE scenario	Every step shows passed	Pass
E2E-04	Counsellor, then System Administrator	Sign out; press Escape and click; sign back in; open Refunds	Sign-in screen shown; all page data cleared; no script errors; no “simulated” wording	Pass

ID	Role	Steps	Expected result	Result
E2E-05	Reception	Record a counter payment on an enrolment	Payment saved; server-issued receipt number shown; no save errors	Pass
E2E-06	Centre Administrator	Register a new student on the 40 / 30 / 30 payment term, paying the first instalment	Schedule shown before confirming; server schedule is Paid / Upcoming / Upcoming; LMS enrol call succeeds	Pass
E2E-07	Management	Approve a pending exceptional discount	Toast confirms approval; no save errors	Pass
E2E-08	System Administrator	Change and save SLA settings	Toast “SLA & follow-up rules saved”	Pass
E2E-09	Counsellor (Karama)	Open the leads list	No Sports City or India leads visible	Pass
E2E-10	System Administrator	Staff → Edit Omar → Issue temporary password; sign in as Omar with it	Temporary password shown once; sign-in lands in the password-change stage	Pass
E2E-11	Centre Administrator	Withdraw an enrolment with 30 sessions attended and request a refund	Suggestion 0 shown; request recorded as an exception awaiting Management; LMS cancel call succeeds	Pass
E2E-12	System Administrator, Counsellor	Open Counsellor Targets, Payment Terms, Refund Rules and LMS Integration (sample data); sign in as a counsellor and open report 21	Every tab renders; sample enrol call shown; counsellor sees the My monthly target tile and their row in report 21	Pass

Testing console scenarios and manual UAT checklist

The Testing console (Settings → Testing console, System Administrator only) runs each scenario through the real code and shows each step as passed or failed.

Scenario	Steps checked
UAE enquiry → enrolment → Telr	Website lead, routing to an eligible counsellor, opportunity, enrolment with server-computed AED fee, Telr payment link, paid callback, receipt, LMS enrol call, ERPNext payment entry, withdrawal with refund suggestion and LMS cancel call
India enquiry → enrolment → Razorpay	Same flow for Bengaluru in INR with Razorpay
Meta lead import	Signed leadgen webhook, form mapping, lead created once even when Meta retries
LMS outage and retry	Injected failure recorded on the sync, scheduler retry succeeds

Manual UAT checklist for the business team, on staging with real staff accounts:

- [ ] Each role signs in, changes the temporary password; System Administrator and Management set up two-step verification
- [ ] Counsellor creates, calls, follows up and qualifies a lead; cannot see another branch
- [ ] Counsellor requests an exceptional discount; Management approves; the discount applies at enrolment once only
- [ ] Branch transfer requested and approved by the Admissions Head; the lead and its tasks move
- [ ] Centre Administrator enrols a new student with first payment; receipt prints with the correct branch series
- [ ] Reception sends a payment link by WhatsApp; the parent pays; payment and receipt appear without staff action
- [ ] Refund requested, capped at the amount paid, then marked processed
- [ ] The enrolment appears in the LMS with the purchased Track and Credits
- [ ] Payment entry appears in ERPNext as a draft
- [ ] SLA escalation notification arrives for an uncalled hot lead
- [ ] Reports match the expected counts for one week of activity
- [ ] System Administrator issues a temporary password and signs a user out everywhere

Version 2 checklist:

- [ ] Management sets October and November counsellor targets; the sum per branch matches the branch target
- [ ] A counsellor sees the My monthly target tile; report 21 matches the enrolments made

- [ ] Each payment term produces the expected schedule in the enrolment form; an instalment past its grace days appears on the Reception tile and in report 22
- [ ] Refund rules confirmed by management; withdrawals at different days and sessions give the expected suggestion; an exception needs the approver
- [ ] LOF issues the Track and Credit codes; they are entered, marked confirmed, and the readiness checklist is all green
- [ ] A real enrolment appears in the LMS with exactly the purchased Credits; a withdrawal removes unused Credits

Requirements traceability

Requirement	Test cases
Sign-in, lockout, strong passwords, forced change	AUT-01, AUT-03, SEC-25, SEC-27, SR2-08, E2E-10
Two-step verification for privileged roles	SEC-28, SEC-29, SR2-09
Server-side sessions, idle timeout, CSRF	SEC-24, SEC-25, SEC-26, E2E-01, E2E-04
Branch-scoped data access	AUT-05–AUT-07, AUT-10, SEC-05, SEC-10, SEC-20, API-02, API-03, SR2-06, E2E-09
Role permissions matrix	AUT-19, AUT-23, TCN-01, SR2-06, E2E-02
Lead capture and routing	API-01, WHK-01–WHK-05, TCN-04–TCN-06, E2E-01
Duplicate detection	API-01
Approvals (transfer, reassignment, discount)	AUT-11–AUT-14, SEC-06–SEC-09, E2E-07
Fee calculation and discounts	UNI-04–UNI-06, AUT-15, SEC-09
Payments, receipts, balances	AUT-16, AUT-23, SEC-04, SEC-11, SEC-18, API-04, E2E-05
Payment links (Telr AED, Razorpay INR)	UNI-16, WHK-10–WHK-12, SEC-19, API-05, TCN-04, TCN-05
Refunds	SEC-15, SR2-04, SR2-05
Gapless record numbers	AUT-22, TCN-09, SR2-01, SR2-02
Communications and consent (WhatsApp, e-mail)	AUT-17, SEC-13, ADP-04, ADP-05, WHK-06, WHK-07

Requirement	Test cases
Telephony (Exotel)	UNI-10, ADP-06, WHK-08, WHK-09
LMS enrol and cancel calls	UNI-08, UNI-09, ADP-01–ADP-03, SEC-12, TCN-07, E2E-06
ERPNext posting	ADP-07, ADP-08
Audit trail and history integrity	AUT-18, SEC-04, SEC-17, SEC-18, SR2-03
Concurrent editing	SEC-16, SEC-17
SLA escalation and follow-ups	TCN-11
Secrets never exposed or logged	AUT-08, AUT-19, UNI-14, SEC-21, TCN-10, SR2-12
Security headers and server secret	SEC-22, SEC-23
Test data isolation	TCN-08, TCN-09, SR2-11
Administrator provisioning	ADM-01, AUT-20, E2E-10
Counsellor targets and achievement	UNI-13, FEA-09–FEA-12, E2E-12
Payment terms and instalments	UNI-08–UNI-10, FEA-01–FEA-04, FEA-10, E2E-06
Refund rules, suggestion and exception approval	UNI-11–UNI-13, FEA-05, FEA-06, FEA-13, FEA-14, TCN-04, E2E-11
LMS integration (enrol and cancel calls, codes, no payment data)	UNI-14, UNI-15, ADP-01–ADP-04, FEA-07–FEA-10, FEA-15, FEA-16, TCN-04, TCN-07, E2E-06, E2E-11, E2E-12

Defects found and closed

ID	Severity	Defect	Status	Verified by
D-01	Critical	Sync accepted unknown operations, skipping all guards	Closed	SEC-01
D-02	High	Records could be moved into the user’s branch	Closed	SEC-05
D-03	High	Lead branch could change without a matching approved transfer	Closed	SEC-06, AUT-11

ID	Severity	Defect	Status	Verified by
D-04	High	Client could set fees, discounts and totals; approvals reusable	Closed	SEC-09, AUT-15
D-05	High	Overpayment, backdating, client receipt numbers, payment edits	Closed	SEC-11, SEC-18
D-06	High	Client-built approvals, messages, LMS call records, notifications	Closed	SEC-07, SEC-12–SEC-14
D-07	High	Session token readable by page scripts	Closed	SEC-24, E2E-01
D-08	High	Forged record numbers accepted	Closed	SR2-01
D-09	High	History lists could be rewritten	Closed	SR2-03
D-10	High	Refunds could exceed the amount paid	Closed	SR2-04
D-11	High	An unchecked edit in the same save could lift the refund cap	Closed	SR2-05
D-12	High	Testing console open to all configuration roles	Closed	TCN-01
D-13	High	Guessable payment link ids; mock links payable in production	Closed	SEC-19
D-14	Medium	No two-step verification	Closed	SEC-28, SEC-29
D-15	Medium	Cross-site sign-in posts accepted	Closed	SR2-08
D-16	Medium	Student 360 exposed payments to roles without access	Closed	SR2-06
D-17	Medium	REST lead creation accepted any field	Closed	SR2-07
D-18	Medium	Secrets could reach integration logs	Closed	SR2-12
D-19	Medium	Test records could reach live providers in production	Closed	SR2-11
D-20	Medium	Concurrent edits overwrote each other	Closed	SEC-16

ID	Severity	Defect	Status	Verified by
D-21	Low	Missing rate limits (two-step disable, sequence blocks)	Closed	SR2-09, SR2-10
D-22	Low	Long pop-ups pushed Save off-screen	Closed	E2E-01
D-23	Low	Centre Administrator first payment at enrolment rejected	Closed	AUT-23, E2E-06
D-24	Low	Previous user's data left in the page after sign-out	Closed	E2E-04
D-25	Low	Leftover "simulated" wording on screens and in sample data	Closed	E2E-04
D-26	Low	No way to issue staff passwords	Closed	E2E-10
D-27	Low	Production seed used the public demo password	Closed	Review of build-seed (masters-only)
D-28	Low	Staging environment missing database and queue bindings	Closed	Build dry run
D-29	High	A refund split into several requests could avoid exception approval	Closed	FEA-13
D-30	High	A late retry of an enrol call could re-open LMS access after a withdrawal	Closed	FEA-15
D-31	High	The overdue-instalment job rewrote whole enrolments and could undo a withdrawal or payment saved at the same moment	Closed	FEA-04 (marker-only update)
D-32	Medium	The requester of a refund exception could approve it; refunds could not be rejected	Closed	FEA-14
D-33	Low	valid_until rolled into the next month for enrolments on the 29th–31st; malformed LMS settings caused a server error; duplicate enrol calls allowed	Closed	FEA-16, FEA-10

Open defects: none.

Entry and exit criteria, and what is not yet tested

Exit criteria for release to staging – all met:

- [x] ~~100% of automated and browser cases pass~~
- [x] ~~No open critical or high defects~~
- [x] ~~Type check clean; production build succeeds~~
- [x] ~~Every security finding has a regression case~~

Exit criteria for production – to be met on staging:

- [ ] Manual UAT checklist signed off by the business owner
- [ ] Each integration passes Test connection and its scenario with real credentials
- [ ] External penetration test with no open high findings
- [ ] Backup and restore rehearsed (D1 Time Travel)

Not yet tested:

Area	Why	Plan
Real provider accounts (Telr, Razorpay, WhatsApp, Meta, Exotel, LMS, ERPNext, Google Calendar, Resend)	Credentials not yet issued; adapters tested against exact stubbed APIs	Run Test connection and scenarios on staging per integration
Cloudflare deployment itself	This workspace cannot reach Cloudflare	First staging deployment, then the smoke checks in the runbook
Load and performance	Not in scope of this build	Measure with expected user counts on staging
Cross-browser and mobile	Automated runs use Chromium desktop	Spot-check Safari, Firefox and phone widths during UAT
Accessibility	Not formally audited	Keyboard and screen-reader pass during UAT
LMS against LOF's real endpoint and codes	Endpoint, token and Track/Credit codes not issued yet; the call format is tested against the sheet and a stub	Enter the codes, run Test connection and the UAE scenario on staging, then check one student in the LMS

Area	Why	Plan
Refund rule values	Placeholders until management confirms them; the calculation itself is tested	Confirm, enter in Settings → Refund Rules, mark confirmed, re-run the UAT refund cases